GDDC Blue Team Operations Playbook

Table of Contents: Order of Operations

1. Step 1: Change Default Credentials
2. Step 2: Check and Lock Users & Groups
3. Step 3: Identify IPs and Ports of Scored Services
4. Step 4: Configure Firewalls
5. Step 5: Disable Cron and Audit Services
6. Step 6: Clear Aliases, SSH Keys, and Backup Configs
7. Step 7: Network Traffic Monitoring & Ongoing Jobs
8. Glossary / Command List
9. GitLab
10. Mattermost
11. GDDC Blue Team Operations Playbook

Step 1: Change Default Credentials

Immediately access all systems and change the default credentials.

Credential List:

- **pfSense:** admin / pfsense
- **Windows Server 2016:** dog / bb123#123#123
- **Ubuntu / Rocky Linux:** dog / bb123#123
- **MySQL (Ubuntu Web Server):** root / bb123#123
- **Mattermost (Rocky Comms Server):** admin or admin@local.host / bb123#123
- **Gitlab (Rocky Gitlab Server):** Root / bb123#123

Password Reset Commands:

- **Linux (Ubuntu/Rocky):** sudo passwd <username>
- **Windows (CMD run as Admin):** net user <username> <new_password>
- **MySQL:** mysql -u root -p -> ALTER USER 'root'@'localhost' IDENTIFIED BY 'new_password'; FLUSH PRIVILEGES;

Step 2: Check and Lock Users & Groups

Do not delete scored users. Lock unauthorized accounts to prevent system breakage.

SCORED USERS <do not delete>

- **Global:** `amarino`, `mdesocio`, `lsmith`, `acapece`, `johnlinux`, `linuswindows`, `alvin`, `simon`, `theodore`, `abauer`
- **Windows Only:** `analyst1` through `analyst8`
- **Gitlab Only:** `scoring_user`

Ubuntu 24.04 & Rocky Linux 9.7

1. **List all users:** cat /etc/passwd
2. **List privileged users:** getent group sudo (Ubuntu) or getent group wheel (Rocky)
3. **Lock an unauthorized user:** sudo usermod -L <username>
4. **Delete a user (if absolutely certain):** sudo userdel -r <username>
5. **Kill locked user's active sessions:** sudo pkill -u <username>

Windows Server 2016

1. **List all local users:** net user
2. **List local administrators:** net localgroup administrators
3. **Lock an unauthorized user:** net user <username> /active:no
4. **Delete a user (if absolutely certain):** net user <username> /delete

---

Step 3: Identify IPs and Ports of Scored Services

Before applying firewalls, you must know exactly what ports are listening, especially for undocumented services like ZeroClaw.

Universal

- Resolve the scoring engine IP immediately: ping scoring.uacyber.org

Ubuntu 24.04 & Rocky Linux 9.7

1. **Identify listening ports and their associated PIDs:** sudo ss -tupln
2. **Verify service status:** sudo systemctl status <service_name>

Windows Server 2016

1. **Identify listening ports and associated PIDs:** netstat -ano | findstr LISTENING
2. **Map PID to Service Name:** tasklist | findstr <PID>

Step 4: Configure Firewalls (Strict Whitelisting)

Implement a default deny policy. Only allow inbound traffic from the Scoring Engine IP and necessary outbound traffic.

Ubuntu 24.04 (UFW)

1. **Reset UFW:** sudo ufw reset

2. **Set default policies:** * sudo ufw default deny incoming
    - sudo ufw default allow outgoing
3. **Whitelist Scoring Engine for specific ports (Repeat for all needed ports):**
    - sudo ufw allow from <SCORING_IP> to any port <PORT>
4. **Enable UFW:** sudo ufw enable
5. **IPTables (Alternative/Supplement for blocking specific malicious IPs):**
    - sudo iptables -I INPUT -s <MALICIOUS_IP> -j DROP

Rocky Linux 9.7 (Firewalld)

1. **Start and enable Firewalld:** sudo systemctl enable --now firewalld
2. **Set default zone to drop:** sudo firewall-cmd --set-default-zone=drop
3. **Whitelist Scoring Engine using rich rules (Repeat for each scored port):**
    - sudo firewall-cmd --permanent --add-rich-rule='rule family="ipv4" source address="<SCORING_IP>" port protocol="tcp" port="<PORT>" accept'
4. **Allow necessary local traffic (e.g., SSH from your jumpbox IP):**
    - sudo firewall-cmd --permanent --add-rich-rule='rule family="ipv4" source address="<YOUR_JUMPBOX_IP>" port protocol="tcp" port="22" accept'
5. **Reload configuration:** sudo firewall-cmd --reload
6. **Verify active rules:** sudo firewall-cmd --list-all

Windows Server 2016 (PowerShell Run as Admin)

1. **Set default block:** * Set-NetFirewallProfile -Profile Domain,Public,Private -DefaultInboundAction Block
2. **Whitelist Scoring Engine (Repeat for each port):**
    - New-NetFirewallRule -DisplayName "Allow Scoring Engine <PORT>" -Direction Inbound -LocalPort <PORT> -Protocol TCP -Action Allow -RemoteAddress <SCORING_IP>
3. **Allow Management (RDP/WinRM) from Jumpbox:**
    - New-NetFirewallRule -DisplayName "Allow RDP" -Direction Inbound -LocalPort 3389 -Protocol TCP -Action Allow -RemoteAddress <YOUR_JUMPBOX_IP>

Step 5: Disable Cron and Audit Services

Sever persistence mechanisms immediately.

Ubuntu 24.04 & Rocky Linux 9.7

1. **Nuke cron.d entirely:** sudo rm -rf /etc/cron.d/*
    - **To view all system crontabs:** ls -la /etc/cron.*
    - **To delete cronjobs for entire host:** rm /var/spool/cron/crontabs/*
    -
2. **Check user crontabs:** for user in $(cut -f1 -d: /etc/passwd); do crontab -u $user -l; done
3. **List all running systemd services:** systemctl list-units --type=service --state=running

4. **Audit suspicious services:** sudo systemctl cat <sus_service.service> (Look at ExecStart for malicious binaries or scripts).
5. **Disable and remove malicious services:**
    - sudo systemctl stop <sus_service.service>
    - sudo systemctl disable <sus_service.service>
    - sudo rm /etc/systemd/system/<sus_service.service>
    - sudo systemctl daemon-reload

Windows Server 2016

1. **Open Task Scheduler:** Run taskschd.msc. Audit the root folder and Microsoft directories for disguised executable triggers.
2. **Audit Services:** Run services.msc. Sort by "Startup Type" and "Status". Look for non-standard services running under LocalSystem.
3. **Disable Malicious Services via CMD:** * sc stop <ServiceName>
    - sc config <ServiceName> start= disabled

Step 6: Clear Aliases, SSH Keys, and Backup Configs

Ensure attackers cannot leverage existing authentications or configurations to regain access.

Linux (Ubuntu/Rocky)

1. **Clear SSH Keys for all users:**
    - Audit: cat ~/.ssh/authorized_keys and cat /root/.ssh/authorized_keys
    - Remove any keys that do not belong to your team.
2. **Check and clear malicious aliases:**
    - cat ~/.bashrc | grep alias
    - cat ~/.bash_aliases
3. **Backup Critical Configurations:**
    - **Gitlab (Rocky):** sudo cp /etc/gitlab/gitlab.rb /etc/gitlab/gitlab.rb.bak
    - **MySQL (Ubuntu):** sudo cp /etc/mysql/my.cnf /etc/mysql/my.cnf.bak
    - **Mattermost (Rocky):** sudo cp /opt/mattermost/config/config.json /opt/mattermost/config/config.json.bak

---

Step 7: Network Traffic Monitoring & Ongoing Jobs

Continuous monitoring is required to catch injected malware or adapt to Red Team methodology.

pfSense (Router/Firewall Monitoring)

1. **Live Firewall Logs:** Navigate to Status > System Logs > Firewall.
    - *Goal:* Look for repeating, blocked inbound attempts to identify attacker IPs.

2. **Packet Capture (Built-in Wireshark equivalent):** Navigate to Diagnostics > Packet Capture.
    - Select the WAN interface.
    - Filter by Port (e.g., port 80) to capture web traffic.
    - Download the .pcap file and open it locally in Wireshark to inspect the payload for SQLi or malicious commands in HTTP GET/POST requests.

Ongoing Monitoring Jobs (Assign to team members)

1. **Monitor Network Traffic (pfSense):** Continuously review firewall logs to identify new IPs attempting to connect. Update firewall block rules dynamically.
2. **Monitor Services (All OS):** Keep systemctl list-units --state=running or services.msc open. Watch for newly spawned services.
3. **Monitor Active Connections (All OS):** * Run watch -n 2 'sudo ss -tupan | grep ESTAB' on Linux to see real-time established connections.
    - If a reverse shell connects, note the foreign IP, find the PID, kill -9 <PID>, and block the IP in the firewall immediately.

Glossary / Command List

1. Identity & Access Management (IAM)

Locking down default credentials and unauthorized users.

Linux (Ubuntu 24.04 / Rocky Linux 9.7)

- **Change Password:** sudo passwd <username>
- **List All Users:** cat /etc/passwd
- **List Admins:** getent group sudo *(Ubuntu)* OR getent group wheel *(Rocky)*
- **Lock User (Recommended):** sudo usermod -L <username>
- **Kill User Sessions:** sudo pkill -u <username>
- **Delete User:** sudo userdel -r <username>

Windows Server 2016

- **Change Password:** net user <username> <new_password>
- **List All Users:** net user
- **List Admins:** net localgroup administrators
- **Lock User:** net user <username> /active:no
- **Delete User:** net user <username> /delete

MySQL

- **Reset Root:** mysql -u root -p $\rightarrow$ ALTER USER 'root'@'localhost' IDENTIFIED BY 'new_password'; FLUSH PRIVILEGES;

---

2. Reconnaissance & Network State

Identifying what is listening, what is established, and scanning for vulnerabilities.

Universal

- **Ping Scoring Engine:** ping scoring.uacyber.org
- **Nmap Service Scan:** nmap -sV --script=vuln <target>
- **Nmap Aggressive Scan:** nmap -A -T4 -Pn --script=vuln <target>

Linux

- **List Listening Ports/PIDs:** sudo ss -tupln *(fallback: netstat -tupln)*
- **List Established Connections:** sudo ss -tupan | grep ESTAB
- **Kill a Process (e.g., Reverse Shell):** sudo kill -9 <PID>

Windows

- **List Listening Ports/PIDs:** netstat -ano | findstr LISTENING
- **Map PID to Service:** tasklist | findstr <PID>

---

3. Firewall Configuration (Default Deny)

Severing unauthorized access while whitelisting the Scoring Engine.

Ubuntu (UFW)

- **Reset & Set Defaults:** * sudo ufw reset
    - sudo ufw default deny incoming
    - sudo ufw default allow outgoing
- **Whitelist IP/Port:** sudo ufw allow from <SCORING_IP> to any port <PORT>
- **Block Specific IP:** sudo ufw deny from <MALICIOUS_IP> to any
- **Enable:** sudo ufw enable

Rocky Linux (Firewalld)

- **Start & Set Default Drop:** * sudo systemctl enable --now firewalld
    - sudo firewall-cmd --set-default-zone=drop
- **Whitelist IP/Port:** sudo firewall-cmd --permanent --add-rich-rule='rule family="ipv4" source address="<SCORING_IP>" port protocol="tcp" port="<PORT>" accept'
- **Apply Changes:** sudo firewall-cmd --reload
- **Verify:** sudo firewall-cmd --list-all

IPTables (Universal Linux Fallback)

- **Block IP:** sudo iptables -I INPUT -s <MALICIOUS_IP> -j DROP

Windows Server (PowerShell Admin)

- **Set Default Block:** Set-NetFirewallProfile -Profile Domain,Public,Private -DefaultInboundAction Block
- **Whitelist IP/Port:** New-NetFirewallRule -DisplayName "Allow Scoring Engine <PORT>" -Direction Inbound -LocalPort <PORT> -Protocol TCP -Action Allow -RemoteAddress <SCORING_IP>

---

4. Eradicating Persistence (Daemons & Cron)

Hunting down malware, reverse shells, and backdoors.

Linux Services (Systemd)

- **List Running Services:** systemctl list-units --type=service --state=running
- **Check Service Status:** sudo systemctl status <service_name>
- **Audit Service Config (Look at ExecStart):** sudo systemctl cat <service_name>
- **Nuke Malicious Service:** 1. sudo systemctl stop <service_name>
  2. sudo systemctl disable <service_name>
  3. sudo rm /etc/systemd/system/<service_name>
  4. sudo systemctl daemon-reload *(Critical: Must reload to finalize removal)*

Linux Cron Jobs

- **List System Crontabs:** ls -la /etc/cron.*
- **Nuke Drop-in Cron Jobs:** sudo rm -rf /etc/cron.d/*
- **Nuke All Host Cronjobs:** rm /var/spool/cron/crontabs/*
- **Audit All User Crontabs:** for user in $(cut -f1 -d: /etc/passwd); do crontab -u $user -l; done
- **Delete Specific User Cron:** crontab -r *(run as that user)*

Windows Services (CMD Admin)

- **Stop Service:** sc stop <ServiceName>
- **Disable Service:** sc config <ServiceName> start= disabled

---

5. Configuration & Cleanup

Removing attacker footprints and securing authenticated access.

Linux

- **Audit SSH Keys:** cat ~/.ssh/authorized_keys and cat /root/.ssh/authorized_keys
- **Audit Aliases:** cat ~/.bashrc | grep alias and cat ~/.bash_aliases

Configuration Backups

- **Gitlab (Rocky):** sudo cp /etc/gitlab/gitlab.rb /etc/gitlab/gitlab.rb.bak
- **MySQL (Ubuntu):** sudo cp /etc/mysql/my.cnf /etc/mysql/my.cnf.bak
- **Mattermost (Rocky):** sudo cp /opt/mattermost/config/config.json /opt/mattermost/config/config.json.bak

WEBGUI GITLAB & MATTERMOST

Phase 1: Web GUI Triage

Log in as an admin via the web interface. Navigate to the **Admin Area** (the wrench icon) to lock the doors.

- **Disable Open Sign-ups:** * *Path:* Admin Area > Settings > General > Sign-up restrictions.
    - *Action:* Uncheck "Sign-up enabled." Attackers often create their own accounts if open registration is left on.
- **Audit Users & SSH Keys:**
    - *Path:* Admin Area > Overview > Users.
    - *Action:* Review the user list. Remember your rule: **Do not delete users** (especially `scoring_user`), as it might break the scoring engine. Instead, **Block** or **Deactivate** any unauthorized users. While inspecting suspicious users, check their "Impersonation Tokens" and "SSH Keys" and delete any that the Red Team may have planted.
- **Lock Down CI/CD Runners:**
    - *Path:* Admin Area > CI/CD > Runners.
    - *Action:* CI/CD pipelines are essentially remote code execution by design. If the scoring engine doesn't require active pipelines, pause or disable shared runners. If an attacker commits a `.gitlab-ci.yml` file, they can use it to spawn a reverse shell.
- **Check Webhooks:**
    - *Path:* Admin Area > System Hooks (and check individual project settings).
    - *Action:* Delete any webhooks sending payloads to external, unrecognized IP addresses.

Phase 2: CLI Commands (Rocky Linux Environment)

Keep these in your back pocket if the Red Team locks you out of the web interface or if you need to make deep system changes.

- **Reset the Root Password (If locked out):**
- Bash

sudo gitlab-rake "gitlab:password:reset[root]"

-
- *This will prompt you to enter and confirm a new password directly from the terminal.*
- **Apply Configuration Changes:**
- Bash

sudo gitlab-ctl reconfigure

-
- *If you ever edit the `/etc/gitlab/gitlab.rb` file (like changing listening ports or database settings), you **must** run this command for the changes to compile and take effect.*
- **Restart All GitLab Services:**
- Bash

sudo gitlab-ctl restart

-
- **Check GitLab Status:**
- Bash

sudo gitlab-ctl status

-
- *This lists all the microservices running under GitLab (like Nginx, PostgreSQL, Redis) and their uptimes. If something keeps crashing, start here.*
- **Tail the Logs (For active monitoring):**
- Bash

sudo gitlab-ctl tail

-
- *This streams all GitLab logs to your terminal in real-time. Useful for catching unauthorized access attempts as they happen.*

Phase 1: Mattermost Web GUI Triage

Just like GitLab, locking down Mattermost via the System Console is much faster than editing JSON files in the terminal. Log in using the admin credentials you secured in Step 1.

- **Disable Open Sign-ups:**
    - *Path:* System Console > Authentication > Signup.

    - *Action:* Set "Enable Open Server" to **False**. This stops the Red Team from simply creating a new user account to spy on your team's comms.
- **Audit Users & Deactivate Attackers:**
    - *Path:* System Console > User Management > Users.
    - *Action:* Review the user list. Ensure you do not touch any scored users. If you see a user that does not belong, change their role from "System Admin" to "Member" (if applicable) and select **Deactivate**.
- **Purge Malicious Webhooks & Integrations:**
    - *Path:* Main Menu (top left) > Integrations.
    - *Action:* Check "Incoming Webhooks," "Outgoing Webhooks," and "Slash Commands." The Red Team will often use incoming webhooks to spam your comms or outgoing webhooks to exfiltrate data whenever certain trigger words are typed. Delete anything undocumented.
- **Revoke Personal Access Tokens:**
    - *Path:* System Console > User Management > Users > (Click on a user) > Manage Tokens.
    - *Action:* Revoke any active tokens on administrator accounts unless explicitly required by the scoring engine.

Phase 2: Mattermost CLI Emergency Operations

If the web interface is inaccessible, or if you need to monitor the server backend, drop into the Rocky Linux terminal.

- **Emergency Admin Password Reset (via mmctl):**
  If you are locked out, use the Mattermost CLI tool (mmctl) using the local socket constraint.
- Bash

sudo /opt/mattermost/bin/mmctl user reset-password admin@local.host --password 'NewSecurePass123!' --local

-
- **Restart the Mattermost Service:**
  If you make a change to /opt/mattermost/config/config.json (like changing the database password), you must restart the daemon.
- Bash

sudo systemctl restart mattermost

-
- **Live Log Monitoring:**
  Tail the logs to watch for unauthorized login attempts or database connection errors in real-time.
- Bash

sudo tail -f /opt/mattermost/logs/mattermost.log

-

Phase 3: Custom Firewall Rules for Rocky Web Servers

Because GitLab and Mattermost are both hosted on Rocky Linux, you will be using firewalld. You must explicitly allow the web traffic ports so the scoring engine can verify the services are up, while dropping everything else.

1. Determine the exact listening ports:

Run sudo ss -tupln.

- GitLab typically runs on **80 (HTTP)**, **443 (HTTPS)**, and **22 (SSH for Git cloning)**.
- Mattermost typically runs on **8065 (HTTP)**, or **80/443** if placed behind a proxy like Nginx.

2. Apply the default drop zone:

Bash
sudo firewall-cmd --set-default-zone=drop

3. Whitelist the Scoring Engine and Jumpbox (Run for each necessary port):

Replace <SCORING_IP>, <JUMPBOX_IP>, and <PORT> appropriately.

Bash
Allow Scoring Engine to access Web/GitLab/Mattermost
sudo firewall-cmd --permanent --add-rich-rule='rule family="ipv4" source address="<SCORING_IP>" port protocol="tcp" port="<PORT>" accept'

Allow YOU to manage the box via SSH
sudo firewall-cmd --permanent --add-rich-rule='rule family="ipv4" source address="<JUMPBOX_IP>" port protocol="tcp" port="22" accept'

4. Reload and Verify:

Bash
sudo firewall-cmd --reload
sudo firewall-cmd --list-all

1. Linux: SUID/SGID Binaries (Hidden Root/Additional Persistence)

Red Teams will often copy /bin/bash or nc to a hidden directory and set the SUID bit. This allows any unprivileged user who runs that file to instantly execute it as root, bypassing your locked-down sudo groups.

- **Find all SUID files on the system:**
- Bash

find / -perm -4000 -type f 2>/dev/null

-
- *Action:* Review the output. If you see things like sudo, passwd, or ping, that is normal. If you see /tmp/.hidden/bash or /usr/bin/python3 with SUID, remove the SUID bit (sudo chmod u-s <file>) or delete the malicious copy.

2. Web Servers: Hunting Web Shells

You mentioned web servers are vulnerable to PHP injection, but you need a fast way to find backdoors already dropped into your web directories. Attackers leave tiny PHP scripts that allow remote command execution.

- **Grep for common web shell functions in web directories:**
- Bash

grep -RnE "(eval\(|base64_decode|system\(|shell_exec\(|passthru\()" /var/www/html/ 2>/dev/null

-
- *(Note: Adjust /var/www/html/ if GitLab or your web app is hosted elsewhere).*
- *Action:* If you find a file like image_upload.php containing eval($_GET['cmd']), quarantine or delete it immediately.

3. Windows: Deep Persistence (Registry & Startup)

Checking services.msc and Scheduled Tasks is great, but Red Teams love using the Windows Registry to ensure their malware runs every time a user logs in.

- **Query the Run keys via CMD:**
- DOS

reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
reg query HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run

-
- *Action:* Look for suspicious executables pointing to C:\Temp, C:\Users\Public, or AppData. If found, delete the key using reg delete <KeyPath> /v <ValueName>.
- **Check the Startup Folder:**
- DOS

dir "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp"

-

4. Windows: Active Directory / Domain Level Checks

Your playbook uses net localgroup administrators, which only checks the local machine. In a competition environment with a Windows Server 2016 instance, it is almost certainly acting as a

Domain Controller. If the Red Team adds an account to the Domain Admins group, local firewall rules and local user locks won't save you.

- **Check Domain Admins:**
- DOS

net group "Domain Admins" /domain

-
- *Action:* If an unauthorized user is in there, remove them immediately: net group "Domain Admins" <username> /delete /domain

5. Linux: PAM Backdoors (Pluggable Authentication Modules)

If you changed all the passwords but the Red Team can still log in via SSH with whatever password they want, they backdoored PAM. This allows them to bypass authentication entirely.

- **Audit PAM configurations (Ubuntu/Rocky):**
- Bash

cat /etc/pam.d/common-auth
cat /etc/pam.d/sshd

-
- *Action:* Look for modules like pam_permit.so in places it shouldn't be, or unauthorized .so files loaded via auth sufficient.

6. Package Integrity Checking

If you suspect the Red Team replaced a standard binary (like ps or ss) with a fake version that hides their malware, you can ask the package manager to verify the hash of installed files against the official repository.

- **Rocky Linux (RPM):**
- Bash

rpm -Va

-
- *(This takes a minute, but looks for altered files. Look for output where the 5 flag is present, meaning the MD5 sum changed).*
- **Ubuntu (dpkg/debsums):**
- Bash

dpkg -V